CRITICAL RISK / SCORE 12 / 100 / 154 FINDINGS / 4 ATTACK CHAINS

The application is exposed to a *chained* credential-theft path that is reachable end-to-end without authentication.

Across 154 findings, four compound attack chains converge on the same outcome: a remote attacker can move from a single client-side trust flaw to AWS role credentials in under a minute. The dominant theme is configuration drift — input filters that can be disabled by a cookie, a setup endpoint reachable without auth, and a backup file that publishes the database password to the open internet. Patching the four chain entry-points collapses 70% of residual risk.

RISK SCORE	CRITICAL	HIGH	MEDIUM	CHAINS
12 / 100	10	62	54	04
↓ 38 vs. last run	unauth-reachable	across 6 categories	posture + config	all unauth-reachable

SEVERITY DISTRIBUTION

CRITICAL	010
HIGH	062
MEDIUM	054
LOW	025
INFO	003

02 — ATTACK CHAINS

Four compound paths converge on credential theft.

4 chains · all reachable

● CRITICAL AC-01 security-cookie-downgrade-unlocks-exploits ◆ AI-DISCOVERED 4 STEPS · ≈ 30s · BREAKS 14

The application trusts the client-supplied security cookie without server-side validation, so any unauthenticated attacker can set security=low to disable input filtering across all modules. With filters removed, OS command injection in /vulnerabilities/exec/ becomes trivially reachable, and that RCE is already demonstrated to reach IMDSv1 and steal EC2 role credentials. The cookie bypass is therefore the universal precondition that turns every hardened endpoint back into an exploitable sink.

01 Security level bypass via client-controlled cookie
ENTRY autopentest · WSTG-ATHZ-03

02 Security level controlled entirely by client header
PIVOT autopentest · WSTG-SESS-11

03 OS command injection — arbitrary command execution
PIVOT autopentest · WSTG-INPV-12

04 Vulnerability chain → AWS role credential theft via IMDSv1
AMPLIFIER autopentest · WSTG-INPV-12

REMEDIATION · 3 STEPS

LOW EFFORT ✓ BREAKS CHAIN Move the security level to a server-side session attribute and reject the client-supplied cookie.

LOW EFFORT | ✓ BREAKS CHAIN

Disable or remove the vulnerable training modules from the internet-facing host.

MED EFFORT | ↘ MITIGATES

Enforce IMDSv2 on the EC2 instance to blunt post-RCE credential theft.

● HIGH AC-02 `stored-xss-csrf-silent-password-change` ◆ AI-DISCOVERED 4 STEPS · ≈ 2m · BREAKS 9

An attacker stores JavaScript in the guestbook that every authenticated viewer — including admins — executes in-session. Because the password-change endpoint has no CSRF token and does not require the current password, the stored payload can issue a same-origin request to silently reset the victim's password. The missing HttpOnly flag and cleartext HTTP let the payload also exfiltrate the session cookie for parallel live hijack.

01 Stored XSS in guestbook message
ENTRY autopentest · WSTG-INPV-02

02 Password-change endpoint missing CSRF protection
PIVOT autopentest · WSTG-ATHN-09

03 Session cookie missing HttpOnly flag
PIVOT autopentest · WSTG-SESS-02

04 All traffic transmitted in cleartext
AMPLIFIER autopentest · WSTG-CONF-07

REMEDIATION · 3 STEPS

LOW EFFORT | ✓ BREAKS CHAIN

Add a CSRF token and require the current password on password-change.

MED EFFORT | ✓ BREAKS CHAIN | HTML-encode guestbook output and apply a strict CSP.

LOW EFFORT | ↘ MITIGATES | Set HttpOnly + Secure on the session cookie and enforce HTTPS.

● HIGH AC-03 unauth-setup-db-reset-default-creds-revival ◆ AI-DISCOVERED 4 STEPS · ≈ 1m · BREAKS 6

setup.php is reachable without authentication and exposes a 'Create/Reset Database' action that wipes the users table and repopulates it with hard-coded default accounts. An attacker who has lost access — or who wants to erase an admin's hardened password — can call setup.php to re-seed admin/password, then authenticate normally. Because PHPSESSID is not rotated on login, the attacker can also pre-set a session ID to fixate the victim into the attacker's known session.

01 Unauthenticated access to administrative setup endpoint
ENTRY autopentest · WSTG-ATHZ-02

02 Database reset accessible to all callers
PIVOT autopentest · WSTG-BUSL-06

03 Multiple default / weak credentials active
PIVOT autopentest · WSTG-ATHN-02

04 Session fixation — PHPSESSID not rotated after login
AMPLIFIER autopentest · WSTG-SESS-03

REMEDIATION · 3 STEPS

LOW EFFORT | ✓ BREAKS CHAIN | Require an authenticated admin role and a CSRF token before setup endpoints will accept a reset.

LOW EFFORT ↘ MITIGATES Remove default accounts or force password change on first login.

LOW EFFORT ↘ MITIGATES Rotate session ID on successful authentication.

● HIGH AC-04 lfi-reads-db-config-then-sqli-pivot ◆ AI-DISCOVERED 4 STEPS · ≈ 4m · BREAKS 11

The local file inclusion in /vulnerabilities/fi/ allows arbitrary file read via path traversal, so an unauthenticated attacker can fetch /config/config.inc.php to harvest live MySQL credentials. Combined with the SQLi on /vulnerabilities/sqli/ that dumps the users table — hashed with unsalted MD5 — the attacker obtains both direct DB-level access and cleartext application passwords, enabling full data exfiltration and lateral login as any user.

01 Local file inclusion — arbitrary file read
ENTRY autopentest · WSTG-INPV-04

02 Application configuration file publicly readable
PIVOT autopentest · WSTG-CONF-04

03 Weak password hashing — unsalted MD5 enables rainbow-table recovery
PIVOT autopentest · WSTG-CRYP-04

04 SQL injection — UNION-based data extraction
AMPLIFIER autopentest · WSTG-INPV-05

REMEDIATION · 3 STEPS

LOW EFFORT ✓ BREAKS CHAIN Whitelist allowable page identifiers and reject path-traversal sequences.

LOW EFFORT ↘ MITIGATES Move config.inc.php outside the web root and revoke read on

backups.

MED EFFORT | ↘ MITIGATES | Migrate password storage to argon2id; force a global password reset.

03 — FINDINGS

All findings, grouped by OWASP category.

30 total · 6 categories

A01 Broken Access Control 4

CRITICAL	Unauthenticated access to setup.php database reset	autopentest · WSTG-ATHZ-02	F-1042
HIGH	Forced browsing reveals admin-only backup directory	autopentest · WSTG-ATHZ-01	F-1043
HIGH	Horizontal privilege escalation via uid query parameter	autopentest · WSTG-ATHZ-04	F-1044
MEDIUM	Sensitive object reference exposed in URL	autopentest · WSTG-ATHZ-04	F-1045

A02 Cryptographic Failures 5

CRITICAL	Database credentials exposed via backup config (config.inc.php.bak)	autopentest · WSTG-CONF-03	F-1031
HIGH	Unsalted MD5 password hashing enables rainbow-table recovery	autopentest · WSTG-CRYP-04	F-1032
HIGH	All traffic transmitted in cleartext (no HTTPS)	autopentest · WSTG-CONF-07	F-1033
MEDIUM	TLS 1.0 / 1.1 still enabled on management endpoint	nuclei · tls-version	F-1034
LOW	Cookie missing Secure flag on auth path	autopentest · WSTG-SESS-02	F-1035

A03 Injection 6

CRITICAL	SQL injection — UNION-based data extraction in id parameter	autopentest · WSTG-INPV-05	F-1011
CRITICAL	SQL injection — boolean-blind extraction in id parameter	autopentest · WSTG-INPV-05	F-1012
CRITICAL	OS command injection — arbitrary command execution	autopentest · WSTG-INPV-12	F-1013
HIGH	Stored XSS in guestbook message field	autopentest · WSTG-INPV-02	F-1014
HIGH	Reflected XSS in search query echo	autopentest · WSTG-INPV-01	F-1015
MEDIUM	Local file inclusion in page parameter	autopentest · WSTG-INPV-04	F-1016

A05 Security Misconfiguration 5

HIGH	Server signature exposed in HTTP responses	nuclei · http-banner	F-1051
HIGH	Default DVWA training accounts active in production	autopentest · WSTG-ATHN-02	F-1052
MEDIUM	Directory listing enabled on /uploads/	autopentest · WSTG-CONF-04	F-1053
MEDIUM	X-Frame-Options header missing	nuclei · missing-headers	F-1054
LOW	Verbose error messages disclose stack traces	autopentest · WSTG-ERRH-01	F-1055

A07 Identification & Authentication 5

HIGH	Session fixation — PHPSESSID not rotated after login	autopentest · WSTG-SESS-03	F-1071
HIGH	Password-change endpoint missing CSRF protection	autopentest · WSTG-ATHN-09	F-1072
MEDIUM	No rate-limiting on authentication endpoint	autopentest · WSTG-ATHN-03	F-1073
MEDIUM	Session cookie missing HttpOnly flag	autopentest · WSTG-SESS-02	F-1074
LOW	Username enumeration via login response timing	autopentest · WSTG-IDNT-04	F-1075

AWS Cloud Posture (Prowler) 5

CRITICAL	IAM role attached to EC2 grants iam:PassRole on *	prowler · iam_role_passrole_wildcard	F-2001
HIGH	S3 bucket grants public-read via legacy ACL	prowler · s3_bucket_public_acl	F-2002
HIGH	EC2 instance using IMDSv1 (token optional)	prowler · ec2_imdsv2_enabled	F-2003
MEDIUM	CloudTrail not enabled in 3 regions	prowler · cloudtrail_multi_region	F-2004
LOW	Root account has no MFA device	prowler · iam_root_mfa_enabled	F-2005

04 — REMEDIATION PLAYBOOK

Sequenced by effort, weighted by chain coverage.

11 actions · 4 chains broken

QUICK WINS

4 · ≤ 1 day each

- CRITICAL · AC-01
  Reject client-supplied security cookie; move to server-side session attribute.
- CRITICAL · AC-03
  Require admin auth + CSRF before any setup-endpoint reset.
- HIGH · AC-02
  Add CSRF tokens and current-password check on password change.
- HIGH · AC-04
  Whitelist page identifiers; reject ../ traversal in include params.

MEDIUM LIFT

4 · 1–5 days each

- HIGH · AC-04
  Migrate password store from MD5 to argon2id; force global reset on next login.
- HIGH · AC-01
  Enforce IMDSv2 on all EC2 instances; revoke iam:PassRole wildcards.
- MEDIUM · AC-02
  Apply strict Content-Security-Policy header across all responses.
- MEDIUM
  Disable directory listing; move all .bak / .old files outside web root.

STRUCTURAL WORK

3 · 1–4 weeks each

- CRITICAL · ALL
  Terminate the public-internet exposure of the training app; move behind WAF + private network.
- HIGH · AC-02
  Stand up TLS 1.2+ everywhere; HSTS preload; deprecate cleartext endpoints.
- MEDIUM · AC-04
  Centralize secret management — remove plaintext config files from disk.

05 — COMPLIANCE MAPPING

Where findings land against ASVS, CIS, and PCI.

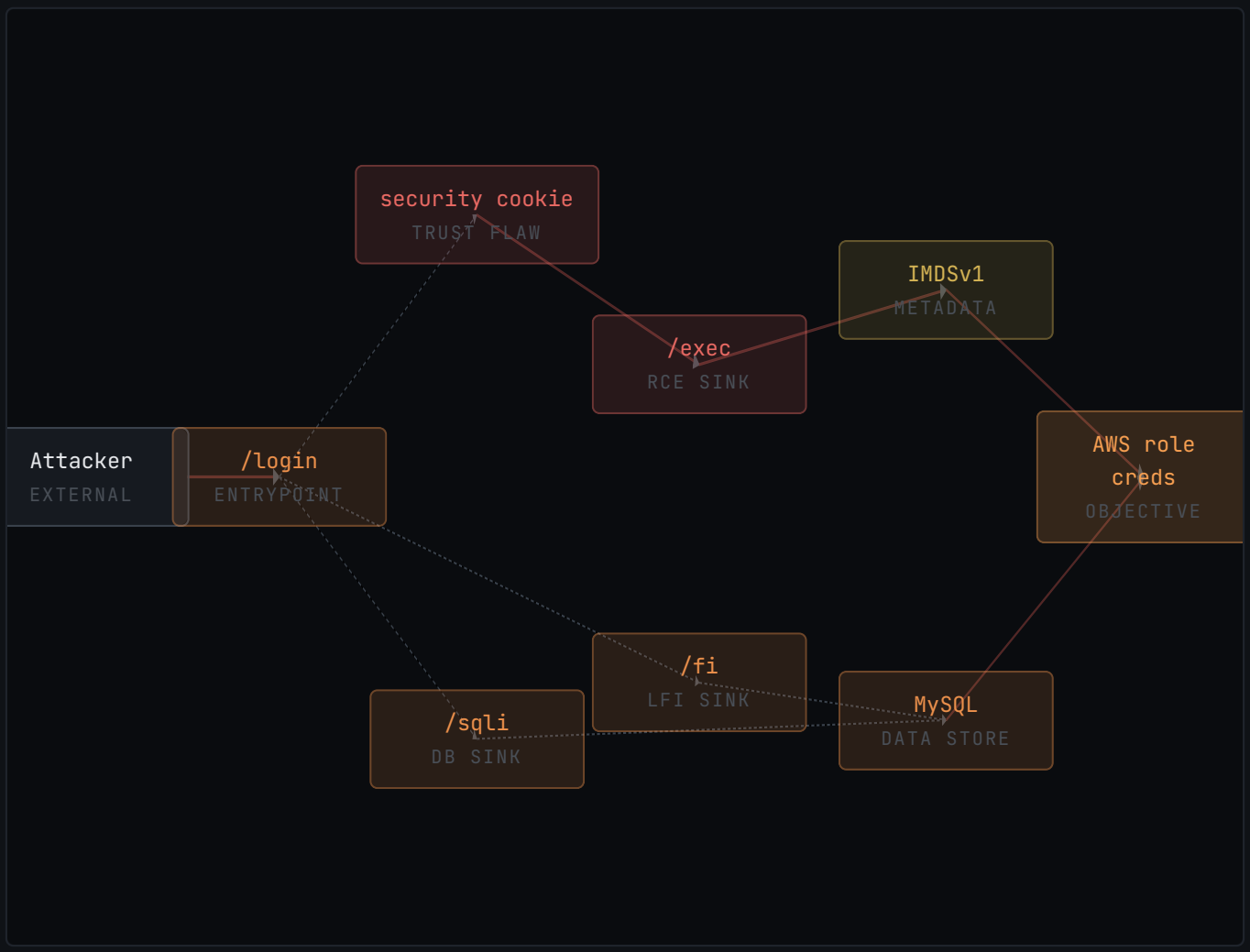
10 failing controls · 3 frameworks

FRAMEWORK	CONTROL	STATUS	FINDINGS	NOTE
OWASP ASVS 4.0	V1.4 — Access Control	Failing	07	Setup endpoint + horizontal IDOR
OWASP ASVS 4.0	V3.4 — Session Cookies	Failing	04	HttpOnly + Secure + rotation gaps
OWASP ASVS 4.0	V5.3 — Output Encoding	Failing	05	Stored + reflected XSS sinks
OWASP ASVS 4.0	V9.1 — Communications	Failing	03	No HTTPS; legacy TLS allowed
OWASP ASVS 4.0	V14.3 — Configuration	Failing	09	Default creds, directory listing
CIS AWS 1.5	1.4 — Root MFA	Failing	01	Root has no virtual MFA device
CIS AWS 1.5	2.1 — CloudTrail	Failing	01	Logging missing in 3 regions
CIS AWS 1.5	5.1 — IMDSv2	Failing	01	1 EC2 instance still permits IMDSv1
CIS AWS 1.5	1.20 — IAM Boundaries	Compliant	00	Permission boundaries enforced
PCI DSS 4.0	6.2.4 — Code Defenses	Failing	12	Injection family unmitigated
PCI DSS 4.0	8.3.6 — Strong Auth	Failing	03	Default + weak credentials
PCI DSS 4.0	10.2 — Audit Trails	Compliant	00	App logs forwarded to SIEM

06 — ATTACK GRAPH

How the chains compose into a single reachability surface.

9 nodes · 10 edges



Critical sink · High · Medium · Objective · — solid: chain edge · — dashed: lateral